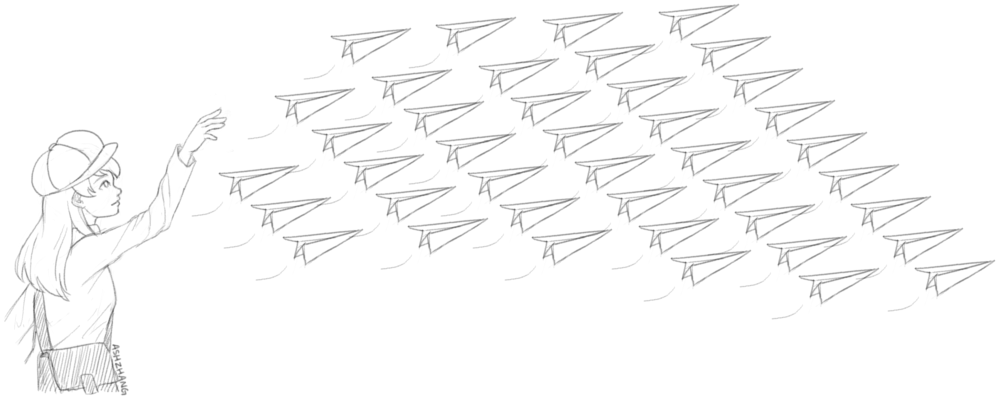
Mirai Botnet and Denial of Service

CS 161 Spring 2026 - Lecture 28



Last time: Domain-Name System (DNS)

- Translates names (e.g., berkeley.edu) into IP addresses
- Name servers are arranged in a domain hierarchy tree
  - Lookups go from root down to the bottom
- DNS traffic goes over UDP → Vulnerable to tampering
- DNS-over-HTTPS (DoH) → More robust to tampering… but not perfect

Today: The Mirai Botnet

A case study on network security.

- What was Mirai?
- How did it work?
- Why did it work?
- What do/did we do about it?

This lecture draws on the paper from USENIX Security 2017: "Understanding the Mirai Botnet"

Warning: Do not try any of this yourself!

Attacking another person's computer
is usually illegal and unethical.

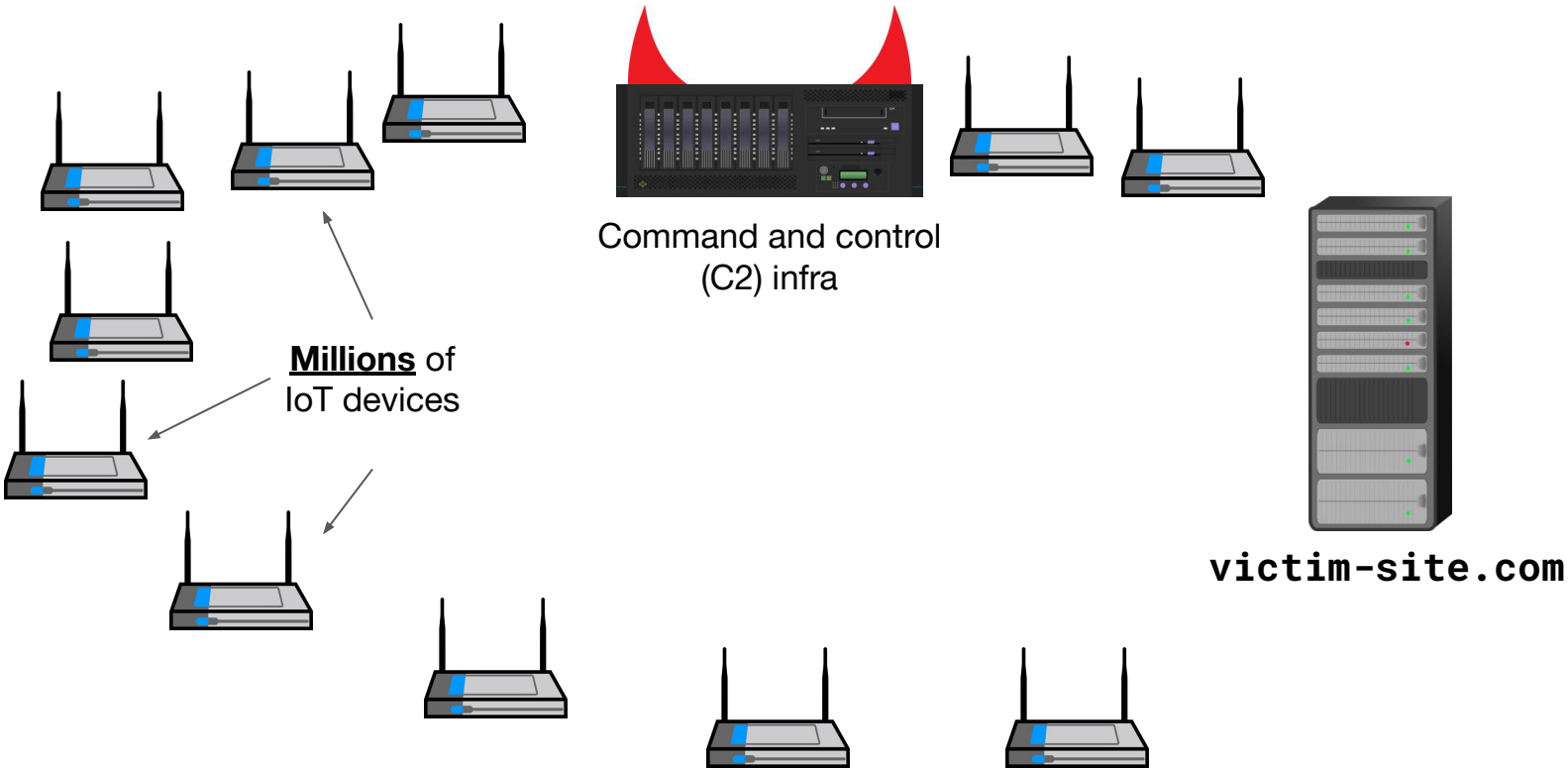
Botnet basics

- **Step 1:** Attacker hijacks a large fleet of networked machines (“Botnet”)
  - Coordinated by a small set of “command and control” (C2) servers
- **Step 2:** Rent out the fleet of machines ⇒ **$$$**

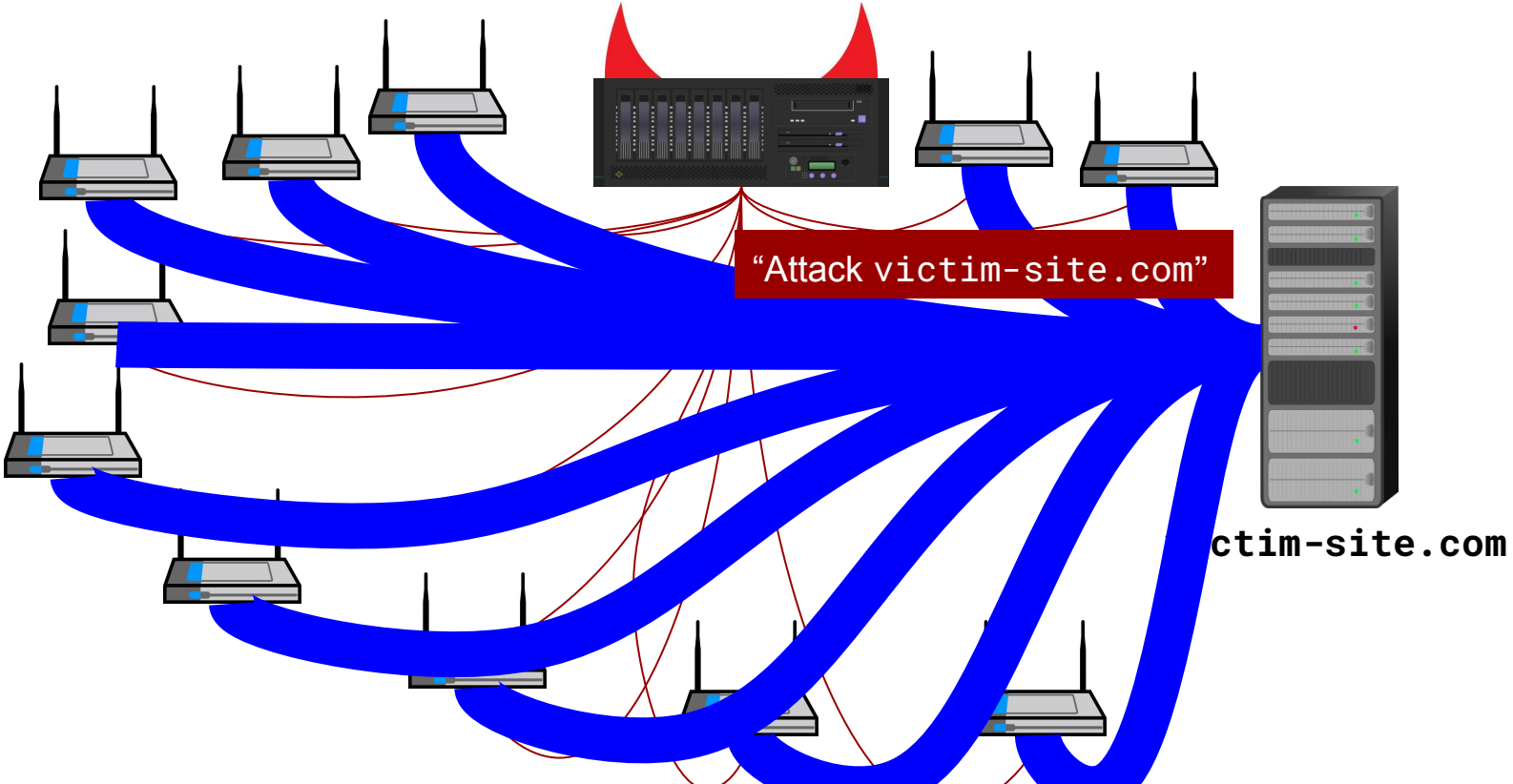
Rent for what?

- Distributed “denial-of-service” attacks = Take down an online service
  - Political
  - Business
  - Gaming (?!)
- Online ad fraud
- Spam email
- Cryptocurrency mining

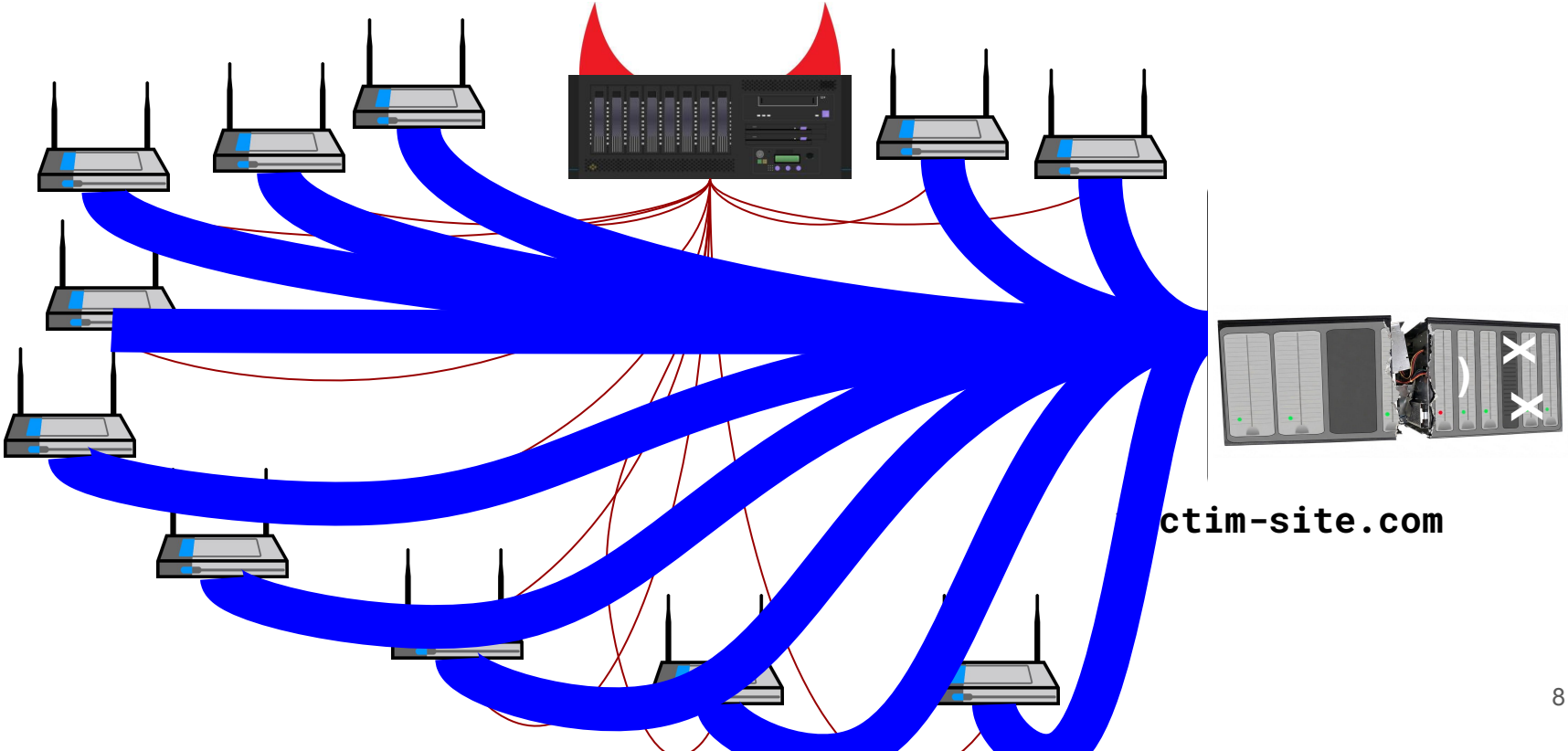
The Mirai botnet (2016-2017)



The Mirai botnet (2016-2017)



The Mirai botnet (2016-2017)



Mirai Botnet: Why it is worth studying

It is simple. **~8k lines of C code** + off-the-shelf exploits

It was effective. Compromised **~300k devices** for 4+ months

Peak DoS throughput of 623 Gbps (2017)

2025: New DDoS record is 30 Tbps
2026: CENIC backbone is 400 Gbps

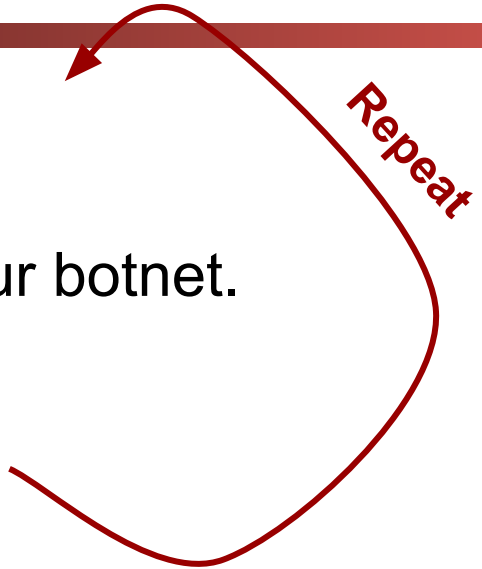
It captures many of the reasons why security is hard.

… and can get the complete source code on Github (!)

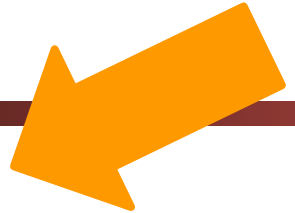
https://blog.cloudflare.com/ddos-threat-report-2025-q3/

Botnet lifecycle

1. Acquire “bot” machines.
2. Find customers who want to rent your botnet.
3. Use bots to mount attack.



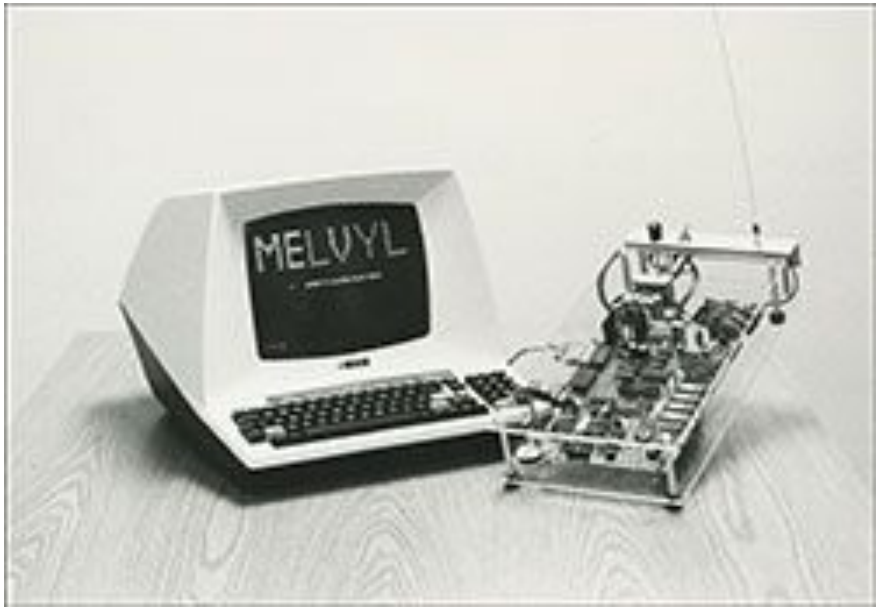
Botnet lifecycle



1. Acquire “bot” machines.
2. Find customers who want to rent your botnet.
3. Use bots to mount attack.

Historical note: Telnet

- Telnet = pre-encryption version of SSH
- Common in the early 1990s for accessing public-library catalogs




Catalog:All Locations
Welcome to Wheaton Public Library's INNOPAC Online Catalog.
You may search INNOPAC by any of the following:
W > WORDS in the Subject, Title or Author
A > AUTHOR, COMPOSER, or PERFORMER
T > TITLE or SERIES
M > MAGAZINE or NEWSPAPER TITLE
B > AUTHOR/TITLE
S > SUBJECT
C > CALL NO
X > Set Material Type
V > VIEW your circulation record
L > Search other LIBRARY catalogs
N > Inter-LIBRARY LOAN requests
I > Library INFORMATION
D > DISCONNECT
Choose one (W,A,T,M,B,S,C,X,V,L,N,I,D)
Please ask for assistance at the Information Desk.

Mirai: Bot acquisition

New bot starts scanning too!

1. **Infected machines scan the IPv4 address space**
   - Pick a random IP address
   - Try to open a telnet connection to it (port 23)

2. **Attempt to log in via telnet with common user/password pairs**

3. **If successful:**
   - Report victim's IP to a reporting server
   - Figure out what hardware victim is running
   - Download and run targeted exploit for that hardware

Common passwords


```
// Set up passwords
add_auth_entry("\x50\x4D\x4D\x56", "\x5A\x41\x11\x17\x13\x13", 10);
add_auth_entry("\x50\x4D\x4D\x56", "\x54\x4B\x58\x5A\x54", 9);
add_auth_entry("\x50\x4D\x4D\x56", "\x43\x46\x4F\x4B\x4C", 8);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "\x43\x46\x4F\x4B\x4C", 7);
add_auth_entry("\x50\x4D\x4D\x56", "\x1A\x1A\x1A\x1A\x1A\x1A", 6);
add_auth_entry("\x50\x4D\x4D\x56", "\x5A\x4F\x4A\x46\x4B\x52\x41", 5);
add_auth_entry("\x50\x4D\x4D\x56", "\x46\x47\x44\x43\x57\x4E\x56", 5);
add_auth_entry("\x50\x4D\x4D\x56", "\x48\x57\x43\x4C\x56\x47\x41\x4A", 5);
add_auth_entry("\x50\x4D\x4D\x56", "\x13\x10\x11\x16\x17\x14", 5);
add_auth_entry("\x50\x4D\x4D\x56", "\x17\x16\x11\x10\x13", 5);
add_auth_entry("\x51\x57\x52\x52\x4D\x50\x56", "\x51\x57\x52\x52\x4D\x50\x56", 5);
add_auth_entry("\x50\x4D\x4D\x56", "", 4);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "\x52\x43\x51\x51\x55\x4D\x50\x46", 4);
add_auth_entry("\x50\x4D\x4D\x56", "\x50\x4D\x4D\x56", 4);
add_auth_entry("\x50\x4D\x4D\x56", "\x13\x10\x11\x16\x17", 4);
add_auth_entry("\x57\x51\x47\x50", "\x57\x51\x47\x50", 3);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "", 3);
add_auth_entry("\x50\x4D\x4D\x56", "\x52\x43\x51\x51", 3);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "\x43\x46\x4F\x4B\x4C\x13\x10\x11\x16", 3);
add_auth_entry("\x50\x4D\x4D\x56", "\x13\x13\x13\x13", 3);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "\x51\x4F\x41\x43\x46\x4F\x4B\x4C", 3);
add_auth_entry("\x43\x46\x4F\x4B\x4C", "\x13\x13\x13\x13", 2);
...
```

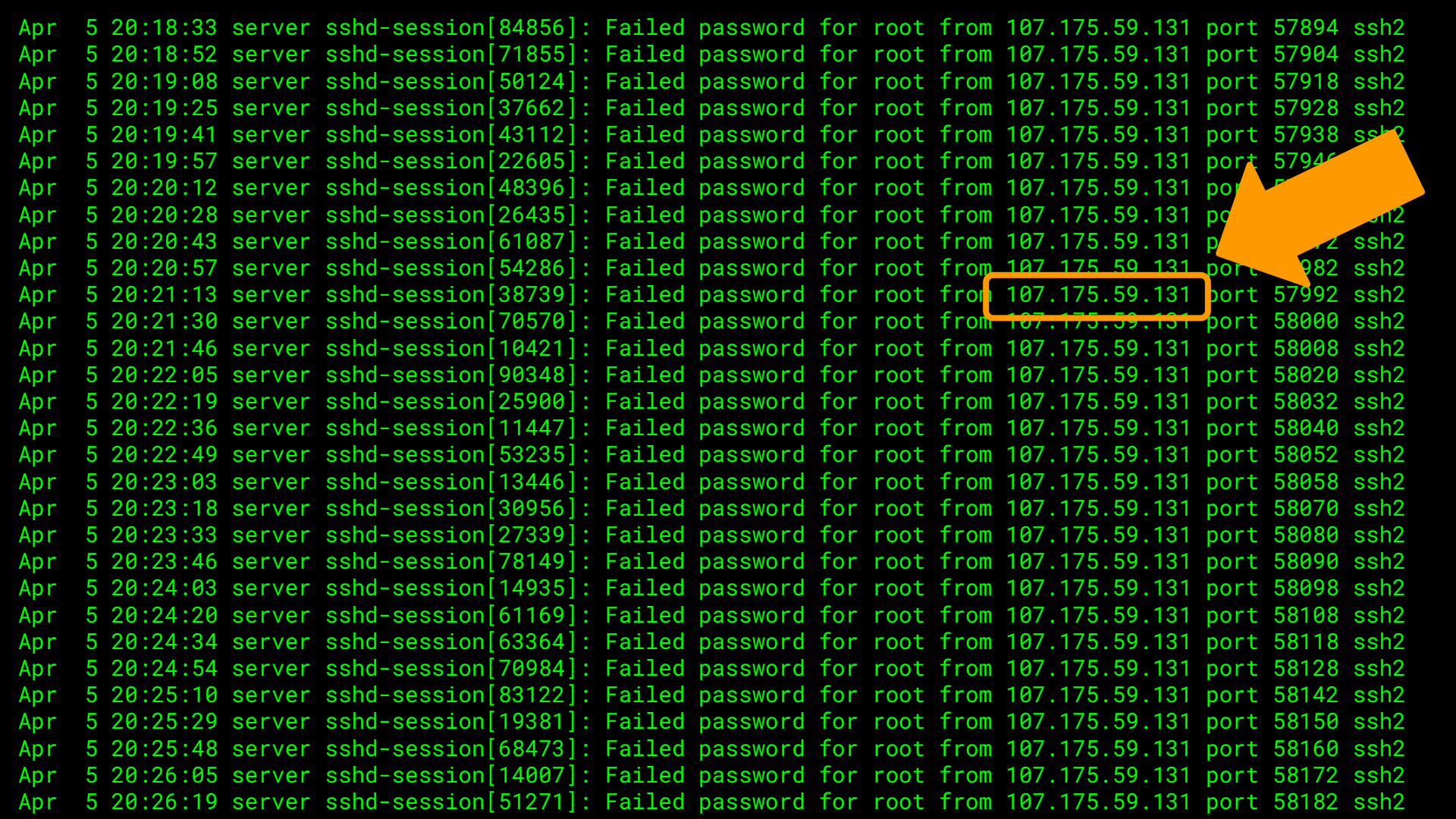
```
// root     xc3511
// root     vizxv
// root     admin
// admin    admin
// root     888888
// root     xmhdipc
// root     default
// root     juantech
// root     123456
// root     54321
// support  support
// root     (none)
// admin    password
// root     root
// root     12345
// user     user
// admin    (none)
// root     pass
// admin    admin1234
// root     1111
// admin    smcadmin
// admin    1111
```

Why does this attack work?

- By 2016, telnet was basically deprecated
  - `ssh` had been around since 1995
- Everyone knew that `root`/123456 was not a good user/password pair
  - Few people configured their server on the public Internet with these credentials
- By 2016, there were tons of IoT devices
  - Many of these were on the public Internet (will say more in a moment)
  - Many also ran telnet servers, likely for automation/configuration
  - Did you check the telnet password on your printer? Your IP camera? Your VoIP phone?
- Incentive issue: Vendor does not care if your IP camera is part of a botnet
  - As long as the camera is cheap and works, the customer will be happy

Password	Device Type	Password	Device Type
123456	ACTi IP Camera	klv1234	HiSilicon IP Camera
anko	ANKO Products DVR	jvbzd	HiSilicon IP Camera
pass	Axis IP Camera	admin	IPX-DDK Network Camera
888888	Dahua DVR	system	IQinVision Cameras
666666	Dahua DVR	meinsm	Mobotix Network Camera
vizxv	Dahua IP Camera	54321	Packet8 VOIP Phone
7ujMko0vizxv	Dahua IP Camera	00000000	Panasonic Printer
7ujMko0admin	Dahua IP Camera	realtek	RealTek Routers
666666	Dahua IP Camera	1111111	Samsung IP Camera
dreambox	Dreambox TV Receiver	xmhdipc	Shenzhen Anran Camera
juantech	Guangzhou Juan Optical	smcadmin	SMC Routers
xc3511	H.264 Chinese DVR	ikwb	Toshiba Network Camera
OxhlwSG8	HiSilicon IP Camera	ubnt	Ubiquiti AirOS Router
cat1029	HiSilicon IP Camera	supervisor	VideoIQ
hi3518	HiSilicon IP Camera	<none>	Vivotek IP Camera
klv123	HiSilicon IP Camera		

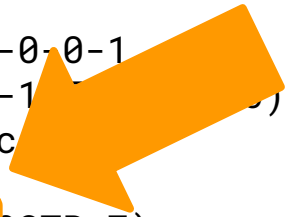
https://www.usenix.org/system/files/conference/usenixsecurity17/sec17-antonakakis.pdf

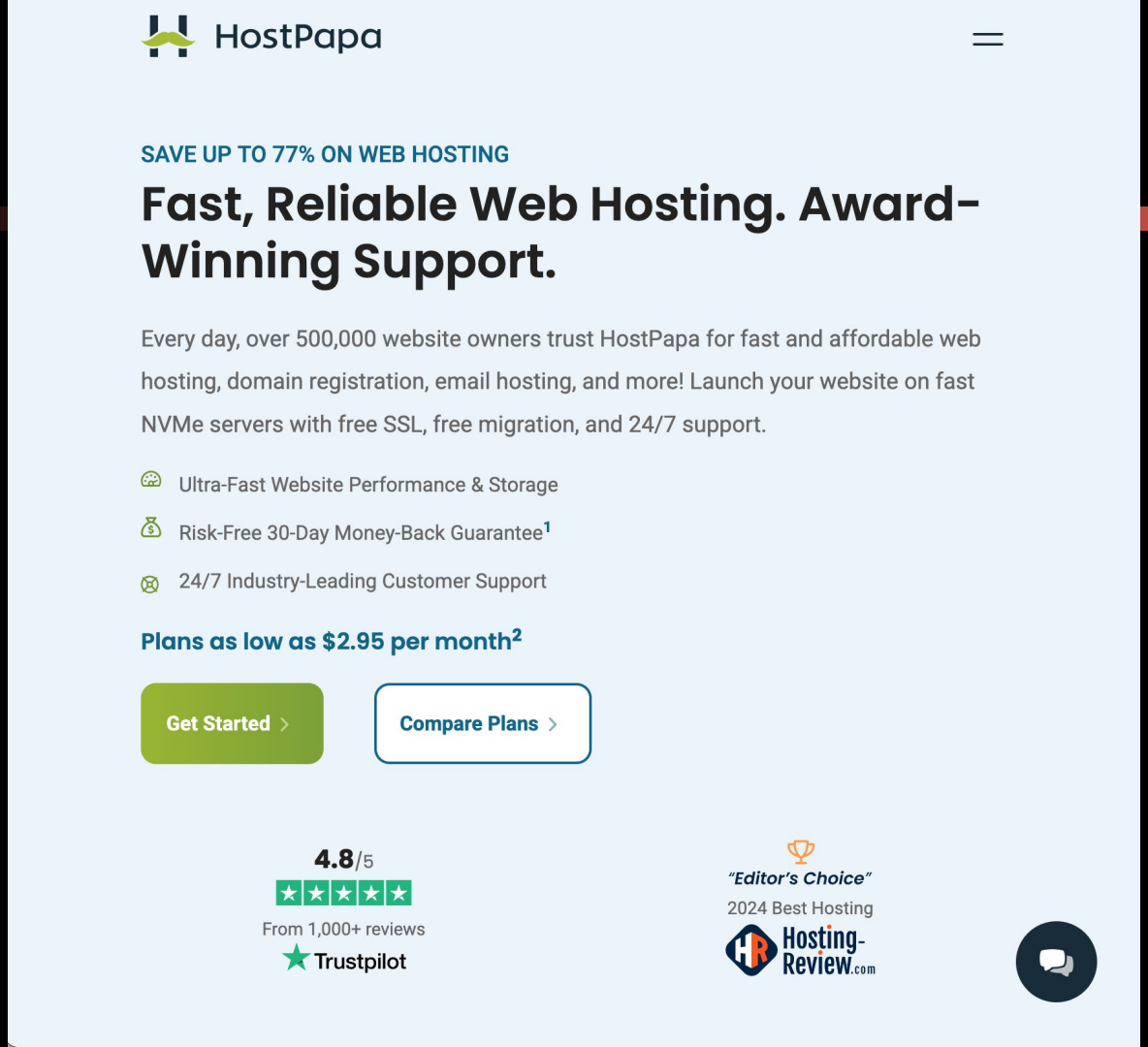

Apr 5 20:18:33 server sshd-session[84856]: Failed password for root from 107.175.59.131 port 57894 ssh2
Apr 5 20:18:52 server sshd-session[71855]: Failed password for root from 107.175.59.131 port 57904 ssh2
Apr 5 20:19:08 server sshd-session[50124]: Failed password for root from 107.175.59.131 port 57918 ssh2
Apr 5 20:19:25 server sshd-session[37662]: Failed password for root from 107.175.59.131 port 57928 ssh2
Apr 5 20:19:41 server sshd-session[43112]: Failed password for root from 107.175.59.131 port 57938
Apr 5 20:19:57 server sshd-session[22605]: Failed password for root from 107.175.59.131
Apr 5 20:20:12 server sshd-session[48396]: Failed password for root from 107.175.59.131
Apr 5 20:20:28 server sshd-session[26435]: Failed password for root from 107.175.59.131
Apr 5 20:20:43 server sshd-session[61087]: Failed password for root from 107.175.59.131
Apr 5 20:20:57 server sshd-session[54286]: Failed password for root from
Apr 5 20:21:13 server sshd-session[38739]: Failed password for root from 107.175.59.131 port 57992 ssh2
Apr 5 20:21:30 server sshd-session[70570]: Failed password for root from
Apr 5 20:21:46 server sshd-session[10421]: Failed password for root from 107.175.59.131 port 58008 ssh2
Apr 5 20:22:05 server sshd-session[90348]: Failed password for root from 107.175.59.131 port 58020 ssh2
Apr 5 20:22:19 server sshd-session[25900]: Failed password for root from 107.175.59.131 port 58032 ssh2
Apr 5 20:22:36 server sshd-session[11447]: Failed password for root from 107.175.59.131 port 58040 ssh2
Apr 5 20:22:49 server sshd-session[53235]: Failed password for root from 107.175.59.131 port 58052 ssh2
Apr 5 20:23:03 server sshd-session[13446]: Failed password for root from 107.175.59.131 port 58058 ssh2
Apr 5 20:23:18 server sshd-session[30956]: Failed password for root from 107.175.59.131 port 58070 ssh2
Apr 5 20:23:33 server sshd-session[27339]: Failed password for root from 107.175.59.131 port 58080 ssh2
Apr 5 20:23:46 server sshd-session[78149]: Failed password for root from 107.175.59.131 port 58090 ssh2
Apr 5 20:24:03 server sshd-session[14935]: Failed password for root from 107.175.59.131 port 58098 ssh2
Apr 5 20:24:20 server sshd-session[61169]: Failed password for root from 107.175.59.131 port 58108 ssh2
Apr 5 20:24:34 server sshd-session[63364]: Failed password for root from 107.175.59.131 port 58118 ssh2
Apr 5 20:24:54 server sshd-session[70984]: Failed password for root from 107.175.59.131 port 58128 ssh2
Apr 5 20:25:10 server sshd-session[83122]: Failed password for root from 107.175.59.131 port 58142 ssh2
Apr 5 20:25:29 server sshd-session[19381]: Failed password for root from 107.175.59.131 port 58150 ssh2
Apr 5 20:25:48 server sshd-session[68473]: Failed password for root from 107.175.59.131 port 58160 ssh2
Apr 5 20:26:05 server sshd-session[14007]: Failed password for root from 107.175.59.131 port 58172 ssh2
Apr 5 20:26:19 server sshd-session[51271]: Failed password for root from 107.175.59.131 port 58182 ssh2

Who is the attacker?


```
Using server whois.arin.net.
Query string: n + 107.175.59.131


NetRange:       107.172.0.0 - 107.175.255.255
CIDR:           107.172.0.0/14
NetName:        CC-17
NetHandle:      NET-107-172-0-0-1
Parent:         NET107 (NET-1
NetType:        Direct Alloc
OriginAS:
Organization:   HostPapa (HOSTP-7)
RegDate:        2013-12-27
Updated:        2024-02-02
Comment:        Geofeed https://geofeeds.oniaas.io/geofeeds.csv
Ref:            https://rdap.arin.net/registry/ip/107.172.0.0
```




HostPapa
SAVE UP TO 77% ON WEB HOSTING
Fast, Reliable Web Hosting. Award-Winning Support.
Every day, over 500,000 website owners trust HostPapa for fast and affordable web hosting, domain registration, email hosting, and more! Launch your website on fast NVMe servers with free SSL, free migration, and 24/7 support.
Ultra-Fast Website Performance & Storage
Risk-Free 30-Day Money-Back Guarantee[1]
24/7 Industry-Leading Customer Support
Plans as low as $2.95 per month[2]
Get Started
Compare Plans
4.8/5
From 1,000+ reviews
Trustpilot
"Editor's Choice"
2024 Best Hosting
Hosting-Review.com

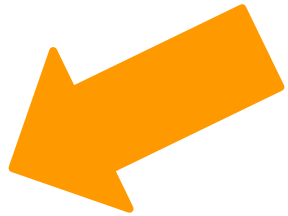
There is no honor among thieves

- There ended up being many variants of Mirai circulating
  - Code of many of them ended up online

- The different Mirai botnets worked to undercut each other
  - After infecting a machine, patch it to prevent other botnets from hijacking it
  - Mirai1 ran DDoS again the command-and-control servers running Mirai 2
  - …

Botnet lifecycle

1. Acquire “bot” machines.
2. Find customers who want to rent your botnet.
3. Use bots to mount attack.



DoS in the News

KrebsonSecurity
In-depth security news and investigation

Link

Digital Hit Men for Hire

Brian Krebs *August 1, 2011*

Cyber attacks designed to knock Web sites off line happen every day, yet shopping for a virtual hit man to launch one of these assaults has traditionally been a dicey affair. That's starting to change: Hackers are openly competing to offer services that can take out a rival online business or to settle a score.

There are dozens of underground forums where members advertise their ability to execute debilitating "distributed denial-of-service" or DDoS attacks for a price. DDoS attack services tend to charge the same prices, and **the average rate for taking a Web site offline is surprisingly affordable: about $5 to $10 per hour; $40 to $50 per day; $350-$400 a week; and upwards of $1,200 per month**.

Search: Search records

Description	Owner	Servers type	Free plan	Layer3/4	Layer7	Abuse Sim	APIs	Payment methods	Status
Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter	Filter
Unmatched DDoS platform. For those who want alot of power I highly recommend this stresser..	Unknown	Owned	Yes	Yes	Yes	Yes	Yes	Crypto	🔥 Hot
[redacted] is one of the Most Powerful IP Booter / Stress Testing DDOS Website On The Public Market.	[redacted]	Rented/API	No	Yes	Yes	Yes	Yes	Crypto	⭐ Premium
[redacted] best ip stresser with advanced layer 4&7 bypass methods,dedicated slots/concurrents, ALL PLANS COME WITH: 86400 Seconds & API Access.	[redacted]	Owned	No	Yes	Yes	Yes	Yes	Crypto	⭐ Premium
[redacted] is the best IP Stresser we provide the best layer4 & layer7, Try now our free	[redacted]	Owned	No	Yes	Yes	Yes	Yes	Crypto	⭐ Premium

[redacted] collects information on public stress test platforms to determine the functions provided by each of them, we publish these informations in our table so that you can see their functionalities clearly and transparently.
All the listed sites should be used ONLY to test the resilience of your network or web applications.
Our site is not affiliated with any of the listed websites, our site take no responsibility from illegal or unethical usage.

[redacted] Project.

Total sites 452

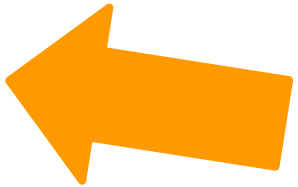
Status Legenda
- 🔥 **Hot** - This site is on fire! Check it out.
- ⭐ **Premium** - Premium trusted site.
- ✅ **Vouched** - Site checked over time, reliable and vouched.
- ☑ **Verified** - Checked site, working as expected.
- ⌛ **Pending** - Site pending verification due to missing information from the owner.
- ❓ **Unverified** - Known unverified site, deal with caution.
- ❗ **Risky** - Recently open unknown site, deal with extreme caution.
- ⚰ **Closed** - Closed site, offline.
- 😡 **Scammer** - Scammer site, dont deal with.

WE ARE BACK
JOIN WITH US

https://www.netscout.com/blog/asert/2024-ddos-hire-landscape-part-1

Botnet lifecycle

1. Acquire “bot” machines.
2. Find customers who want to rent your botnet.
3. Use bots to mount attack.



Denial of service (DoS)

- A service is set up to support
  - *X* requests per second
  - *Y* MB of traffic per second
- System designer sets these limits to handle **normal/honest** load
- An adversary can generate **huge** load
  - With cleverly formed requests that force the server to do a lot of work (“amplification”)
  - By controlling a large number of (basically honest) clients (“distributed DoS”)
- Either way, the system will not be available for honest users
  - Existential threat for online businesses

Example: Cloud service for filling out PDF forms

- Form-filling service
  - Client sends server a 20 KB JSON blob
  - Server replies with a PDF (in 1 second of compute)

- A compromised device on a modern home network has 200 Mbps of bandwidth
  - = 1,250 requests/sec
  - = 1,250 (sec of cloud compute)/sec
  - = $0.0225 (cloud cost)/sec

- Imagine an attacker controlling 10,000 such devices
  - = $225 cloud cost/sec
  - = $13,500 cloud cost/hour
  - = $324,000 cloud cost/day

⇒ I will take service offline almost instantly.

Mirai had many DoS attack engines

Could instruct a bot to send:

- **TCP** SYN (connection open) segments
- **UDP** datagrams – DNS requests, Valve game traffic, etc.
- **HTTP** GET requests

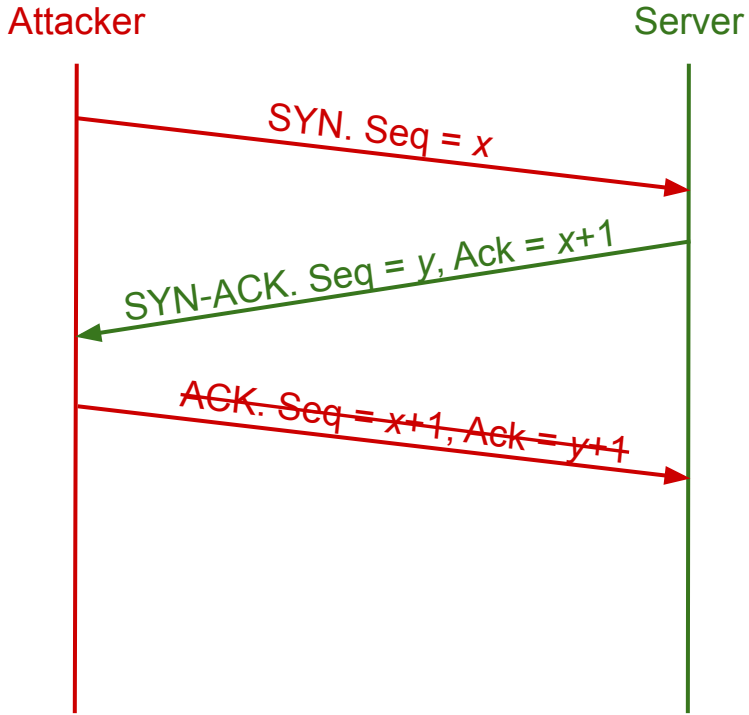
Customer would pick one depending on what it was trying to take down.

Mostly, bots would just send (a lot of) honest/well-formed packets

→ Difficult to defend against!

Example DoS strategy: TCP SYN Flooding

- When attacker sends TCP SYN, server stores some state about TCP flow
  - Sequence numbers, buffered data, etc.
- Attacker doesn't store anything
  - Can send many SYNs very quickly
- Server will eventually stop accepting TCP connections



DoS/Botnet Defenses



DDoS Defense: Content-distribution networks

- You would like to provision your website to handle 100 Tbps of traffic
  - This will handle even a big DDoS attack
  - But you only see one of these attacks every 10 years
  - ⇒ **Not a good use of your money**

- Idea: DoS-defense company owns the 100 Tbps infrastructure
  - Shared amongst all of their many customers
  - Likely that only a small number of customers gets hit with DDoS at once
  - ⇒ **Cost of big infrastructure amortized over many customers**

- **Examples:** Akamai, Google, Fastly, and CloudFlare

Botnet defense: Fix the economic incentives

SECTION 1. (Part 4 of Division 3 of the CA Civil Code, updated 2018)

TITLE 1.81.26. Security of Connected Devices

1798.91.04. [...] if a connected device is equipped with a means for authentication outside a local area network, it shall [use one of these methods:]

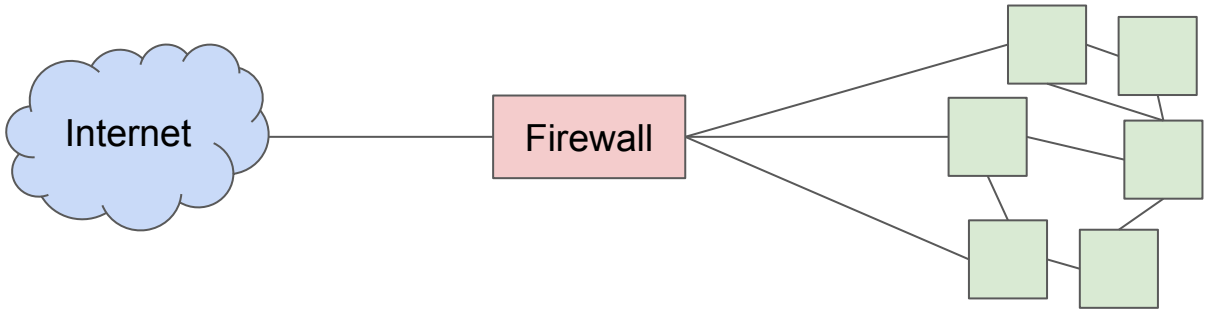
(1) The **preprogrammed password is unique** to each device manufactured.

(2) The device contains a security feature that **requires a user to generate a new means of authentication** before access is granted to the device for the first time.

→ Still does not address the many old devices out there.

Botnet defense: Firewall

- At the network border, enforce limits on outgoing/incoming traffic
- Limits are often based only on source/dest IP and port number
  - **ALLOW** outgoing port 80 and 443 (HTTP/S) to any IP
  - **ALLOW** incoming port 80 and 443 (HTTP/S) only to known web server
  - **DENY** incoming port 23 (Telnet) to all hosts
  - **ALLOW** incoming port 22 (SSH) only from sysadmin's home IP
- Fancier firewall: Disconnect devices behaving "suspiciously"
  - Much nuance/complexity there



Summary: Mirai and denial of service

- **What was Mirai?**
  - Botnet of 100,000s of IoT devices
- **How did it work?**
  - Take over Internet-connected devices via default user/password
  - Compromised bots then scan for more bots to compromise
- **Why did it work?**
  - Lots of cheap devices on the Internet
  - Vendors didn't care about security → Easy targets
- **What do/did we do about it?**
  - CA: Eliminate predictable default passwords for IoT devices
  - Corp. networks: Detect and block botnet traffic